ENTERPRISE DATA GOVERNANCE FRAMEWORK DESIGN & IMPLEMENTATION FOR DIGITAL BANKING TRANSFORMATION

DATA GOVERNANCE POLICY

Document Control

Item	Value
Policy Name	Enterprise Data Governance Policy
Version	1.0
Owner	Chief Data Officer
Approved By	Data Governance Council
Review Frequency	Annual

1. POLICY OVERVIEW

1.1. Purpose

This policy establishes the framework for managing data as a strategic enterprise asset to ensure quality, integrity, security, compliance, and accountability.

1.2. Scope

This policy applies to:

- Employees
- Contractors
- Third Parties

Data includes:

- Customer Data
- Financial Data
- Product Data
- Transaction Data
- Regulatory Data

2. DATA GOVERNANCE PRINCIPLES

1. Data is an enterprise asset
2. Ownership and accountability are mandatory
3. Data quality is proactively managed
4. Security and privacy are enforced by design
5. Sensitive data must be protected
6. Metadata must be documented

3. ROLES & RESPONSIBILITIES (RACI-ALIGNED)

3.1. Chief Data Officer (CDO)

Responsible for:

- Enterprise Data Strategy
- Governance leadership
- Regulatory alignment

3.2. Data Owner

Responsible for:

- Approve definitions
- Data quality accountability
- Issue resolution

3.3. Data Steward

Responsible for:

- Data definitions
- Data quality monitoring
- Metadata maintenance

3.4. IT Custodian

Responsible for the technical implementation and operation of data management controls, including:

- Security controls
- Infrastructure
- Backup & Recovery
- Access management

RACI Overview

Activity	Data Owner	Data Steward	IT Custodian	DGO
Approve business data definitions	A	R	C	C
Define and maintain DQ rules	A	R	C	C
Monitor DQ and coordinate remediation	A	R	C	C
Maintain business metadata	C	R	C	A
Approve business data access	A	C	C	I
Provision or revoke technical access	C	I	R/A*	I
Resolve domain data issues	A	R	C	C
Escalate cross-domain issues	C	C	C	R/A*

Legend: R = Responsible, A = Accountable, C = Consulted, I = Informed

*R/A means Responsible and Accountable may be assigned to the same function for certain operational activities. If the matrix requires one Accountable role per activity, explicitly assign a single decision owner and separate approval from execution.

This matrix is a starting proposal. Adapt it to the bank's authority structure, particularly for sensitive data access, conflicts of interest, and information security.

4. DATA CLASSIFICATION POLICY

4.1. Classification Levels

Level	Description	Example
Public	Information approved for public disclosure that poses no risk if disclosed externally	• Corporate website content • Press releases • Marketing brochures • Published annual reports • Public interest rates • Public branch information

Level	Description	Example
Internal	Information intended for internal business use only	• Internal policies • Process documentation • Organization charts • Internal project plans • Meeting minutes • Employee directories
Confidential	Sensitive business information requiring controlled access	• Customer account information • Credit scoring data • Internal financial reports • Product development documents • Vendor contracts • Business intelligence reports
Restricted (PII / highly sensitive)	Highly sensitive information requiring the highest level of protection	• Customer Personally Identifiable Information (PII) • Customer contact information • Transaction Information • Authentication Credentials • Passwords • Encryption Keys • Biometric Data • KYC Documents • AML Investigation Data • Fraud Investigation Data • Regulatory Examination Findings • Core Banking Database Exports

4.2. Handling Rules

Level	Encryption	Access	Masking
Public	Not required	Open	No
Internal	Optional	Role-based	No
Confidential	Required	Restricted	Partial
Restricted (PII / highly sensitive)	Mandatory	Strict RBAC	Full masking

5. DATA QUALITY POLICY

5.1. Data Quality Dimensions

- Accuracy
- Completeness
- Consistency
- Timeliness
- Uniqueness
- Validity
- Integrity
- Availability
- Precision
- Reasonableness

5.2. Data Quality Rules (Example)

Domain	Rule	Threshold
Customer	Customer Full Name must not be null or blank	100% completeness
Customer	Email must comply with the valid email format	98% accuracy
Customer	Each customer must have one unique CIF Number	100% uniqueness
Account	Every account must have a valid account number	100% completeness
Account	Account Status must match approved values	100% validity
Transaction	Transaction Amount must be greater than zero	100% validity
Transaction	Transaction Date cannot be a future date	100% validity
Transaction	Currency code must comply with the ISO 4217 standard	100% validity

Domain	Rule	Threshold
Loan	Loan amount must be greater than zero	100% validity
Loan	Loan Maturity Date must be greater than Loan Start Date	100% consistency
KYC	NIK must be populated for all Indonesian customers	100% completeness
KYC	NIK must contain exactly 16 digits	100% validity
KYC	Customer onboarding must include mandatory KYC documents	100% completeness
Regulatory Reporting	All mandatory regulatory reporting fields must be populated	100% completeness

5.3. Data Quality Scorecard (Example)

Domain	Rule ID	KPI	Target
Customer	DQ-CUST-001	Name Completeness	100%
Customer	DQ-CUST-005	CIF Uniqueness	100%
Account	DQ-ACC-001	Account Completeness	100%
Transaction	DQ-TRX-004	Duplicate Transactions	0
Loan	DQ-LOAN-002	Loan Date Consistency	100%
KYC	DQ-KYC-002	NIK Validity	100%
Regulatory	DQ-REG-002	Timeliness	100%

5.4. Monitoring

1. Automated data quality checks
2. Data Quality Scorecard
3. Issue tracking & remediation workflow

Critical Data Elements (CDE) Recommended for Data Quality Monitoring:

1. Customer CIF Number
2. Customer Full Name
3. NIK (National ID Number)
4. Customer Date of Birth
5. Account Number
6. Account Status
7. Transaction ID
8. Transaction Amount
9. Loan Account Number
10. Loan Amount
11. Credit Score
12. KYC Status
13. AML Risk Rating
14. Regulatory Reporting Reference Number
15. Customer Consent Status

6. DATA ACCESS & SECURITY POLICY

6.1. Access Control

Access Control Principles:

6.1.1. Role-Based Access Control (RBAC) — Mandatory

All access rights shall be assigned based on predefined business roles.

6.1.2. Attribute-Based Access Control (ABAC)

ABAC may be implemented for high-volume or context-sensitive access scenarios.

Access decisions may consider:

- User Role
- Business Unit
- Geographic Location
- Customer Segment
- Data Classification Level
- Device Type
- Access Time
- Network Location

Examples:

Scenario	Access Decision
Indonesian Operations Staff	Access Indonesian customer data only
Fraud Analyst	Access fraud datasets only
Offshore Vendor	Restricted from accessing Restricted Data
Third-Party Auditor	Read-only access during audit period

6.1.3. Least privilege principle enforced

Users shall be granted the minimum level of access required to perform their job responsibilities.

Requirements:

✓ No excessive privileges

✓ No shared accounts

✓ No permanent privileged access without justification

✓ Access must be removed immediately upon role change or termination

6.2. Authentication & Authorization

6.2.1. Authentication Requirements

Multi-Factor Authentication (MFA)

MFA shall be mandatory for:

- Core Banking Systems
- Mobile Banking Administration Systems
- Internet Banking Administration Portals
- Data Governance Platforms
- Data Catalog Platforms
- Data Warehouse
- Regulatory Reporting Systems
- Cloud Platforms
- Privileged Accounts

Accepted MFA methods:

- Authenticator Applications
- Hardware Security Tokens
- Biometric Authentication
- Push Notification Authentication

SMS OTP shall only be used as a secondary option where appropriate.

6.2.2. Privileged Access Management (PAM)

All privileged accounts shall be managed through a PAM solution.

Privileged accounts include:

- Database Administrators
- System Administrators
- Cloud Administrators
- Security Administrators

Requirements:

✓ Session Monitoring

✓ Password Vaulting

✓ Privileged Session Recording

✓ Just-In-Time (JIT) Access

✓ Temporary Privilege Elevation

6.2.3. Quarterly Access Review

Access rights shall be reviewed every quarter.

6.2.3.1. Review Participants

- Data Owners
- Business Managers
- Information Security Team
- Data Governance Office

6.2.3.2. Review Activities

- User Access Validation
- Role Validation
- Privileged Access Review
- Dormant Account Review
- SoD Conflict Detection

6.2.3.3. Target KPI

KPI	Target
Quarterly Access Review Completion	100%
Unauthorized Access Detected	0
Dormant Accounts Removed	100%

6.2.4. User Lifecycle Management

6.2.4.1. Joiner

New employees receive access only after:

- Manager Approval
- Data Owner Approval
- Security Validation

6.2.4.2. Mover

Role changes trigger:

- Access Revalidation
- Privilege Adjustment
- SoD Review

6.2.4.3. Leaver

Upon termination:

- Immediate account deactivation
- Access revocation within 24 hours
- Token recovery
- Session termination

6.3. Data Protection

6.3.1. Data Encryption

6.3.1.1. Encryption at Rest

All Confidential and Restricted Data must be encrypted while stored.

Applies to:

- Databases
- Data Warehouses
- Data Lakes
- File Storage
- Backup Storage
- Cloud Storage

Recommended Standards:

Control	Standard
Database Encryption	AES-256
File Encryption	AES-256
Backup Encryption	AES-256
Key Management	HSM or Enterprise KMS

6.3.1.2. Encryption in Transit

All data transmissions must be encrypted.

Applies to:

- Internal APIs
- External APIs
- Mobile Banking Traffic
- Internet Banking Traffic
- Inter-System Communication
- Cloud Connectivity

Recommended Standards:

Control	Standard
Web Traffic	TLS 1.3
API Communication	TLS 1.2+
VPN Communication	IPSec VPN
Secure File Transfer	SFTP

6.3.2. Data Masking

Personally Identifiable Information (PII) must be masked when displayed to unauthorized users.

Examples:

Data Element	Original	Masked
NIK	3275011234567890	3275********7890
Account Number	1234567890123456	**********3456
Credit Card Number	4111111111111111	**** **** **** 1111
Mobile Number	081234567890	0812****7890
Email Address	john.doe@email.com	jo***@email.com

6.3.3. Dynamic Data Masking

The system shall automatically determine masking levels based on user roles.

Example:

Role	View PII
Customer Service	Partial Masking
Relationship Manager	Partial Masking
Data Analyst	Fully Masked
Fraud Investigator	Full Access
Compliance Officer	Full Access

6.3.4. Tokenization

Tokenization shall be implemented for highly sensitive data elements such as:

- Account Numbers
- Card Numbers
- Customer Identifiers

6.3.5. Data Loss Prevention (DLP)

The bank shall implement DLP controls to prevent unauthorized disclosure of sensitive data.

Monitoring Scope:

- Email
- Web Uploads
- USB Devices
- Cloud Storage
- Printing Activities
- Collaboration Platforms

6.3.6. Security Monitoring & Audit Logging

All access to Confidential and Restricted Data shall be logged.

Audit logs must capture:

- User ID
- Timestamp
- Source IP Address
- Accessed Dataset
- Activity Type
- Approval Reference

Log retention period:
Minimum 1 year, or longer if required by banking regulations.

6.3.7. Data Backup & Recovery

6.3.7.1. Requirements

- Daily Incremental Backup
- Weekly Full Backup
- Offsite Backup Storage
- Disaster Recovery Replication

6.3.7.2. Recovery Targets

Metric	Target
Recovery Time Objective (RTO)	≤ 4 Hours
Recovery Point Objective (RPO)	≤ 15 Minutes

7. DATA LIFECYCLE MANAGEMENT

7.1. Lifecycle Stages

1. Creation
2. Storage
3. Usage
4. Archival
5. Deletion

7.2. Retention Policy (Example)

Data	Owner	Retention	Disposal
Customer	Retail Banking	Active +2 yrs	Secure Delete
Loan	Lending	10 yrs	Archive
Fraud	Fraud	7 yrs	Archive
AML	Compliance	Legal Requirement	Archive

Note: *Retention periods shown are illustrative defaults and must be confirmed with Legal/Compliance based on applicable tax, accounting, payment, and data-protection requirements.*

7.3. Deletion

1. Secure deletion required
2. Must comply with regulatory requirements

8. METADATA & DATA CATALOG POLICY

8.1. Requirements

- All critical data must be registered in data catalog
- Business glossary must be maintained

8.2. Metadata Coverage

- Data definitions
- Data owner & steward
- Lineage
- Data classification

9. DATA LINEAGE & TRACEABILITY

1. End-to-end lineage must be documented
   - Target: 100% of Tier-1 / critical datasets have documented end-to-end lineage within the data catalog.
2. Impact analysis required before changes
3. Mandatory for critical datasets

10. MASTER DATA MANAGEMENT (MDM)

10.1. Scope

- Customer Master Data
- Product Master Data
- Vendor Master Data

10.2. Rules

1. Single source of truth

   Each Master Data Domain shall have one authoritative source recognized as the official system of record.
2. Golden record management

   A Golden Record is the most complete, accurate, validated, and trusted representation of a master data entity.
3. Deduplication processes

   To identify, merge, and eliminate duplicate records across systems.

10.3. MDM Data Quality Rules

10.3.1. Customer Master

Rule	Target	Notes
Customer ID / CIF Completeness	100%	Every active customer record must have a CIF.
Customer Identity Completeness	100% of mandatory fields	NIK must be populated where applicable and required for KYC.
Duplicate Customer Rate	< 0.5%	Define the matching method, denominator, and duplicate resolution procedure.
Email Format Validity	≥ 98% of populated email fields	Measure email structure and format; a valid format does not guarantee that the address is active.
Customer Address Completeness	≥ 95% of mandatory fields	Define mandatory address fields based on business requirements and applicable regulations.
Customer Status Validity	100%	Status values must comply with the approved list of values.
Customer Record Uniqueness	100% after deduplication	Ensure each customer entity has a unique master identity under the approved matching rules.

10.3.2. Product Master

Rule	Target	Notes
Product Code Completeness	100%	Every product must have a product code.
Product Code Uniqueness	100%	Product codes must not be duplicated within the defined numbering scope.
Product Status Validity	100%	Status must comply with approved values, such as Active, Inactive, or Retired.
Product Pricing Accuracy	≥ 99%	Fees or interest rates must match the approved authoritative source, including effective-date checks.
Product Currency Validity	100%	Currency codes must comply with the applicable ISO 4217 standard and be permitted for the relevant product.
Product Effective-Date Validity	100%	The end date must not precede the start date unless explicitly permitted by an approved business rule.

10.3.3. Vendor Master

Rule	Target	Notes
Vendor ID Completeness	100%	Every vendor must have an internal master identifier.
Vendor Legal Name Completeness	100%	An approved vendor must have a legal name recorded.
Vendor Registration / Tax ID Validity	100% where applicable	Validate according to entity type, jurisdiction, and applicable legal or tax requirements.
Duplicate Vendor Rate	< 0.5%	Measure duplicates using legal identity, tax identification where applicable, and other matching attributes.
Vendor Status Validity	100%	Status must comply with the approved list of values.
Vendor Risk Rating Completeness	100% for vendors requiring assessment	Apply according to risk classification and third-party assessment requirements.

10.3.4 Account Master

Rule	Target
Account ID / Account Number Completeness	100% for accounts required to have an account number
Account Number Uniqueness	100% within the defined system scope
Account Status Validity	100%
Account-to-Customer Relationship Integrity	100% for mandatory relationships
Account Type Validity	100%
Account Currency Validity	100%

11. DATA ISSUE MANAGEMENT

11.1. Issue Classification

1. Critical (business impact)
2. High
3. Medium
4. Low

SLA Table (Example):

Severity	Initial Response	Target Resolution
Critical	< 4 Hours	< 24 Hours
High	< 1 Business Day	< 5 Business Days
Medium	< 2 Business Days	< 10 Business Days
Low	< 5 Business Days	< 30 Business Days

11.2. Workflow

1. Issue detected
2. Logged in tracking system
3. Assigned to Data Steward
4. Root cause analysis
5. Resolution & validation

11.3. Data Security & Privacy Incident Management

1. Detect and classify incidents
2. Containment and access revocation where necessary
3. Notify Security, Privacy Officer, Legal, and Governance Lead
4. For regulated personal-data incidents, follow applicable notification obligations
5. Post-incident RCA and corrective actions

12. COMPLIANCE & REGULATOR

12.1. Applicable Regulations

12.1.1. Personal Data Protection

This policy aligns with applicable data protection and electronic-system regulations, including Indonesia's Personal Data Protection Law (UU No. 27/2022) and relevant implementing regulations. GDPR principles may be adopted as a reference framework where appropriate.

12.1.2. Financial transaction compliance

12.2. Audit

1. Regular internal audit
2. External audit readiness

12.3. Non-Compliance

1. Escalation to Governance Council
2. Corrective action required

12.4. Exception Management & Policy Waiver

Requests for temporary policy exceptions must be documented, approved by the Data Owner and Information Security, reviewed by the Governance Council for high-risk cases, and include expiration date, compensating controls, and remediation plan.

13. GOVERNANCE KPIs

- Data Quality Score (Target: ≥98%)
- Data Ownership Coverage (Target: 100%)
- Data Stewardship Coverage (Target: 100%)
- Data Incident Reduction (Target: ≥ 20% Reduction YoY)
- Open Critical Data Incidents (Target: 0)
- Repeat Data Issues (Target: < 5%)
- Critical Issue Resolution SLA Compliance (Target: ≥ 95%)
- Overall SLA Compliance (Target: ≥ 95%)
- Customer PII Protection Compliance (Target: 100%)
- Unauthorized Data Access Incidents (Target: 0)
- Data Classification Coverage (Target: 100%)
- Master Data Accuracy (Target: ≥ 99%)

14. ENFORCEMENT

1. Mandatory compliance for all employees
2. Violations subject to disciplinary action

15. REVIEW & MAINTENANCE

1. Policy reviewed annually
2. Updated based on regulatory changes